

Data Protection Guidelines

The purpose of this page is to provide guidance around when and how to appropriately protect sensitive data elements.

If you have any questions, concerns or feedback, please contact the Data Trust Office at privacy@loblaw.ca

Data Protection Guidelines

- Sensitive Data must be identified and protected at its point of origin (source). This protection must be maintained throughout the entire data lifecycle, including when data is in transit and at rest in downstream systems.
- If a data element is identified as Sensitive Data but is not protected at the source, appropriate protection controls must be applied before it is stored or replicated.
- Access to Sensitive Data in its unprotected, clear-text format is strictly controlled and requires a documented, valid business justification submitted through the formal detokenization request process maintained by the Data Trust Office.
- The transfer of any unprotected Sensitive Data between systems (on-premises or external/cloud) is prohibited unless secured by an approved data-in-transit encryption method reviewed and approved by the Cyber Security team.
- PI/PHI data should not be copied into or stored in as clear text in lower environments unless appropriate exceptions/approvals have been obtained from the Data Trust Office and Security teams.

Security Guidelines

Standard	Rationale
All data elements have a security classification to manage access and determine data protection. Security classifications are - <i>Restricted, Confidential, Internal or Public</i>	• Public: Data intended for public use that will not adversely affect enterprise operations, assets, reputation, or privacy obligations. • Internal: Data not intended for parties external to enterprise. However, data can, with an applicable business use case, be provided on a need-to-know basis to third parties. This data, if disclosed, will minimally affect Enterprise operations, assets, reputation or privacy obligations • Confidential: Data intended for limited use within the Enterprise that, if disclosed inappropriately, will seriously affect Enterprise operations, assets, reputation or privacy obligations. • Restricted: Data that is highly sensitive and/or regulated by law (e.g. PI, PCI, PHI) and/or is intended for very limited use within the Enterprise. This data, if disclosed inappropriately, will significantly affect Enterprise operations, assets, reputation or privacy and compliance obligations.

All sensitive data elements with
Treatment=Tokenize/One Way Hash - should
be tokenized/One Way Hashed

- Tokenization or One Way Hashing are field-level protection methods. Technical custodians have the ability to prescribe the specific technology used to achieve protection of data.
 - Tokenization swaps the sensitive data element with an exchangeable token and secures the sensitive data outside of the original environment
 - One-way hashing is a process that permanently scrambles data into a unique code, known as a hash. This process is designed to be irreversible, making it practically impossible to turn the hash back into the original data.
- Additional data protection methods which may be referenced in this document include:
 - Encryption: converting data into an unreadable format using an algorithm and key. Data can be reversed into a readable format with the key.
 - Masking: Hiding parts of sensitive data while keeping the format intact. Often irreversible in practice. For example, saving a phone number as *** - *** - ****.
 - Pseudonymization: replacing identifiable data with pseudonyms (fake identifiers). Reversible under controlled conditions
 - Anonymization: Removing or altering data so individuals can no longer be identified. Irreversible
- If detokenized or clear text data elements are found, please notify the Technical Custodian of the application and the Data Trust Office (privacy@loblaw.ca) so that the appropriate remediation actions are taken.

All sensitive data elements with <i>Treatment=DB Encrypt/Encryption at Rest</i> require database-level encryption to be applied	Elements with <i>Treatment=DB Encrypt/Encryption at Rest</i> only require to be housed in an encrypted database. When these elements are called/selected by an <i>authorized</i> user, they decrypt in flight from the back end to the user's Result Window. No <i>field-level</i> treatment is required on these elements
All personal information (PI) and personal health information (PHI) must be encrypted in transit during transmission and processing using approved cryptographic protocols.	In flight elements must be secured using <i>Transport Layer Security 1.2</i> at a minimum

Sensitive Data Elements Checklist

****As defined by the Data Trust Office and Cyber Security Teams - last updated and approved April 2026***

The Sensitive Data Elements Checklist is intended to be a living document that will change from time to time, please review this document periodically to ensure you have the most accurate and up to date information. This document provides a sensitivity rating for individual personal information data elements and the respective treatment of the data per data element.

Note:

- Basic rule of thumb: ***identifiability = sensitivity***
- Personal Information (PI): Any information about an identifiable individual. This includes anything that identifies or could be reasonably associated with an individual, including their location, background, financial, or social circumstances. Even an individual's name, address and telephone number are personal information
- Personal Health Information (PHI): Any information that identifies or can identify an individual and relates to the state of an individual's mental or physical health or the treatment they are receiving. More specifically, personal health information includes both diagnostic, treatment and care information, and/or registration information. Multiple data elements that are low

sensitivity, when combined or associated with a medium or high-risk element will raise risk sensitivity of the data elements (toxic combinations).

- Vendor information is generally not considered PI other than when considering Sole Proprietorships, and with some forms of Partnerships. These business types typically use the personal information (address, name, financial) of the owner(s) of the business.
- This document should not be used to circumvent Security or Data & Privacy assessment and approval processes and should only be used as a guideline.

Should there be any issues with determining sensitivity of a data element alone or in combination with other elements or situations where the prescribed treatment cannot be applied due to business requirements, please contact the Data Trust Office:

privacy@loblaw.ca

For information relating to the classification of the data or treatment of data from a security perspective please contact

asksecurity@loblaw.ca

Type of Data / Data Element	Privacy Sensitivity	Security Classification	Treatment
Personal Information (PI)			
Government-issued identification number	High	Restricted	One-way hash
National Identification Number	High	Restricted	One-way hash
Passport Number	High	Restricted	One-way hash
Social Insurance Number (SIN)	High	Restricted	One-way hash
Driver's License	High	Restricted	One-way hash
Image of an Individual (Photograph)	High	Restricted	DB Encrypt/Encryption at Rest

Mother's Maiden Name	High	Restricted	Tokenize
Video Recording of an Individual	High	Restricted	Tokenize
Age	Moderate	Restricted	Tokenize
An Alias	Moderate	Restricted	DB Encrypt/Encryption at Rest
Citizenship or immigration status	Moderate	Restricted	DB Encrypt/Encryption at Rest
Date of Birth	Moderate	Restricted	Tokenize
Distinguishing physical characteristics	Moderate	Restricted	DB Encrypt/Encryption at Rest
E-mail Address	Moderate	Restricted	Tokenize
Full Name (could be higher risk if name is unique or attached to a person of notoriety)	Moderate	Restricted	Tokenize
Gender, including Self-Identified Gender	Moderate	Restricted	DB Encrypt/Encryption at Rest
Non-Financial Account numbers	Moderate	Restricted	Tokenize
PC Optimum card number (barcode number)	High	Restricted	One-way hash
License plate number	Moderate	Restricted	DB Encrypt/Encryption at Rest
Place of Birth	Moderate	Restricted	DB Encrypt/Encryption at Rest
Postal Code / P.O. Box	Moderate	Restricted	Tokenize last 3 alpha digits
Race / Ethnicity	Moderate	Restricted	DB Encrypt/Encryption at Rest
Social Media Inferences – Facebook, Twitter, Instagram, etc.	Moderate	Restricted	DB Encrypt/Encryption at Rest

Street Address	Moderate	Restricted	Tokenize
Telephone / Cell Number	Moderate	Restricted	Tokenize
Vehicle Identification number (VIN)	Moderate	Confidential	DB Encrypt/Encryption at Rest
Voice recording	High	Restricted	DB Encrypt/Encryption at Rest
Education	Low	Confidential	DB Encrypt/Encryption at Rest
First Name	Low	Confidential	Tokenize
Last Name	Low	Confidential	Tokenize
Biometrics			
Eyes – Retina Recognition	High	Restricted	One-way Hash
Eyes – Iris Recognition	High	Restricted	One-way Hash
Facial Recognition	High	Restricted	One-way Hash
Fingerprint	High	Restricted	One-way Hash
Finger Geometry	High	Restricted	Tokenize
General Biometric Identifiers	High	Restricted	Tokenize
Hand Geometry	High	Restricted	Tokenize
Signature Recognition	High	Restricted	Tokenize
Voice – Speaker Identification / Verification / Authentication	High	Restricted	One-way Hash
Financial (PCI)			
Claims and insurance history	High	Confidential	DB Encrypt/Encryption at Rest

Credit information reported to credit bureaus, reporting agencies, insurers, or other lenders	High	Confidential	DB Encrypt/Encryption at Rest
Credit Score	High	Confidential	DB Encrypt/Encryption at Rest
Beacon Score	High	Confidential	DB Encrypt/Encryption at Rest
Credit card number	High	Restricted	Tokenize
Financial (Bank) account numbers	High	Restricted	Tokenize
Income	High	Restricted	Tokenize
Joint account holder information	High	Restricted	Tokenize
Net worth	High	Restricted	Tokenize
Online Banking Password	High	Restricted	One-way Hash
Salary (Customer/Client)	High	Restricted	Tokenize
Substitute Decision Maker information (POA documents)	High	Restricted	Tokenize
PIN Code	High	Restricted	One-way Hash
Taxpayer Identification Number (BN) (Sole Proprietorships & Partnerships)	High	Restricted	Tokenize
Assets	Moderate	Restricted	DB Encrypt/Encryption at Rest
Debit card number	Moderate	Restricted	Tokenize
Financial account history	Moderate	Restricted	DB Encrypt/Encryption at Rest
Liabilities	Moderate	Restricted	DB Encrypt/Encryption at Rest

Online Banking Username	Moderate	Restricted	Tokenize
Payment records	Moderate	Restricted	DB Encrypt/Encryption at Rest
Investment horizon	Low	Restricted	DB Encrypt/Encryption at Rest
Investment knowledge	Low	Restricted	DB Encrypt/Encryption at Rest
Investment objectives	Low	Restricted	DB Encrypt/Encryption at Rest
Savings Goals	Low	Restricted	DB Encrypt/Encryption at Rest
Personal Health Information (PHI)			
Medical Device Identifiers / Serial Numbers	High	Restricted	Tokenize
Family History	High	Restricted	DB Encrypt/Encryption at Rest
Health Card Numbers	High	Restricted	Lowers: One-way hash Prod: Tokenize
Health Plan Numbers	High	Restricted	Tokenize
Medical History	High	Restricted	DB Encrypt/Encryption at rest for unstructured data Lowers: one-way hash Prod: tokenize
Medical Information shared with Insurance Providers	High	Restricted	DB Encrypt/Encryption at rest for unstructured data Lowers: one-way hash Prod: tokenize

Medical Insurance Coverage and Claims History (payment and eligibility)	High	Restricted	DB Encrypt/Encryption at rest for unstructured data Lowere: one-way hash Prod: tokenize
Medical / Physician Notes / Reports / Summaries	High	Restricted	DB Encrypt/Encryption at rest for unstructured data Lowere: one-way hash Prod: tokenize
Diagnostic Images (e.g. X-Rays / Ultrasound / Sonogram)	High	Restricted	DB Encrypt/Encryption at Rest
Biomedical Specimen (e.g. cheek swab)	High	Restricted	DB Encrypt/Encryption at Rest
Medical profile including Prescription	High	Restricted	DB Encrypt/Encryption at rest for unstructured data Lowere: one-way hash Prod: tokenize
Genetic Information	High	Restricted	Tokenize
Treatment information (including care plans)	High	Restricted	DB Encrypt/Encryption at Rest
Reports/Summaries (including HCP notes, reports – consultation, cardiovascular, respiratory, lab results, adverse reactions to medications, etc.)	High	Restricted	DB Encrypt/Encryption at Rest
Healthcare Provider information	High	Restricted	DB Encrypt/Encryption at Rest
Substitute Decision Maker (POA documents)	High	Restricted	Tokenize

Caregiver Information	High	Restricted	Tokenize
Blood Type	High	Restricted	DB Encrypt/Encryption at Rest
Dosage	Moderate	Restricted	DB Encrypt/Encryption at Rest
Medical Conditions			
Diet	High	Restricted	DB Encrypt/Encryption at Rest
Reproductive Factors	High	Restricted	DB Encrypt/Encryption at Rest
Physical Activity	High	Restricted	DB Encrypt/Encryption at Rest
Anthropometric Measures (Body Measurements)	High	Restricted	DB Encrypt/Encryption at Rest
Substance Abuse Type	High	Restricted	DB Encrypt/Encryption at Rest
Psychological Condition	High	Restricted	DB Encrypt/Encryption at Rest
Disease Type	High	Restricted	DB Encrypt/Encryption at Rest
Technological (Mobile / Phones / Laptop / Devices)			
Audience Segmentation Data (e.g. a combination of signals, traits and segments data)	High	Restricted	DB Encrypt/Encryption at Rest
Device ID	High	Restricted	Tokenize
Device Fingerprint	High	Restricted	One-way Hash
Device Facial Recognition Pattern	High	Restricted	One-way Hash

Geo-Location Tracker Data	High	Restricted	Tokenize
Online Behavior Tracking Data	High	Restricted	DB Encrypt/Encryption at Rest
Online Behavior Session Recording	High	Restricted	DB Encrypt/Encryption at Rest
Session Recordings	High	Restricted	DB Encrypt/Encryption at Rest
Cookies Data	Moderate	Restricted	DB Encrypt/Encryption at Rest
Consent Data / Choices	Moderate	Restricted	DB Encrypt/Encryption at Rest
Metadata	Moderate	Restricted	DB Encrypt/Encryption at Rest
MAC Address	Moderate	Restricted	DB Encrypt/Encryption at Rest
IP Address	Moderate	Restricted	DB Encrypt/Encryption at Rest
Wallet ID	Moderate	Restricted	Lowers: One-way hash Prod: tokenize
Unique Identifier (UID)	Moderate	Restricted	Lowers: One-way hash Prod: tokenize
Patient Identifiers (PAAID, etc.)	Moderate	Restricted	Lowers: One-way hash Prod: tokenize
PCID	Moderate	Restricted	Lowers: One-way hash Prod: tokenize
Colleague (Employee)			
Allergies	High	Restricted	DB Encrypt/Encryption at Rest
Banking Payroll Information	High	Restricted	Tokenize
Colleague Complaints and Claims	High	Restricted	DB Encrypt/Encryption at Rest

Disabilities	High	Restricted	DB Encrypt/Encryption at Rest
Disciplinary Actions (HR)	High	Restricted	DB Encrypt/Encryption at Rest
Employment Litigation Documentation	High	Restricted	Tokenize
Family / Dependent/ Beneficiary Information	High	Restricted	Tokenize
Passwords	High	Restricted	One-Way Hash
Aboriginal Status	Moderate	Restricted	DB Encrypt/Encryption at Rest
Benefit Information	Moderate	Restricted	DB Encrypt/Encryption at Rest
Emergency Contact Information	Moderate	Restricted	Tokenize
Colleague License plate number	Moderate	Restricted	DB Encrypt/Encryption at Rest
Colleague Personal Phone Number	Moderate	Restricted	Tokenize
Colleague User ID	Moderate	Confidential	Tokenize
Colleague Employee Number	Moderate	Confidential	Tokenize
Employment status (including leave of absence)	Moderate	Restricted	DB Encrypt/Encryption at Rest
Gender, Including Self-Identified Gender	Moderate	Restricted	DB Encrypt/Encryption at Rest
Image (Photograph)	Moderate	Restricted	DB Encrypt/Encryption at Rest
Job Grade (exec level)	Moderate	Confidential	DB Encrypt/Encryption at Rest
Marital Status	Moderate	Restricted	DB Encrypt/Encryption at Rest

Minority or Protected Status	Moderate	Restricted	DB Encrypt/Encryption at Rest
Performance Review	Moderate	Confidential	DB Encrypt/Encryption at Rest
Pension Information	Moderate	Restricted	DB Encrypt/Encryption at Rest
References used to Verify Information on Applications	Moderate	Restricted	DB Encrypt/Encryption at Rest
Resume	Moderate	Restricted	DB Encrypt/Encryption at Rest
Salary (Based on job grade)	Moderate	Restricted	Tokenize
Talent / HR flag	Moderate	Restricted	DB Encrypt/Encryption at Rest
Time and attendance	Moderate	Restricted	DB Encrypt/Encryption at Rest
Training and Related Records	Moderate	Confidential	DB Encrypt/Encryption at Rest
Video Recording	Moderate	Restricted	DB Encrypt/Encryption at Rest
Work Address	Moderate	Confidential	DB Encrypt/Encryption at Rest
Educational History	Low	Restricted	DB Encrypt/Encryption at Rest
Email Address	Low	Confidential	DB Encrypt/Encryption at Rest
Employment History	Low	Restricted	DB Encrypt/Encryption at Rest
Geographical location or indicator	Low	Restricted	DB Encrypt/Encryption at Rest
Position title	None	Confidential	DB Encrypt/Encryption at Rest
Position Code	None	Confidential	DB Encrypt/Encryption at Rest
Business Unit / Department	None	Confidential	DB Encrypt/Encryption at Rest
Country / Province	None	Confidential	DB Encrypt/Encryption at Rest

Colleague work number	None	Confidential	DB Encrypt/Encryption at Rest
Department or Division	None	Confidential	DB Encrypt/Encryption at Rest
Vendor Information			
Sole Proprietorship			
Sole Proprietorship - Banking Information	High	Confidential	DB Encrypt/Encryption at Rest
Financial Institution Number	High	Confidential	DB Encrypt/Encryption at Rest
Bank Branch	High	Confidential	DB Encrypt/Encryption at Rest
Bank Account Number	High	Confidential	Tokenize
Bank Identifier Code (BIC) for Large Value	High	Confidential	DB Encrypt/Encryption at Rest
International Bank Number	High	Confidential	DB Encrypt/Encryption at Rest
Sole Proprietorship – Tax Number	High	Confidential	DB Encrypt/Encryption at Rest
Sole Proprietorship – Name	Moderate	Confidential	DB Encrypt/Encryption at Rest
Sole Proprietorship - Address	Moderate	Confidential	DB Encrypt/Encryption at Rest
City	Moderate	Confidential	DB Encrypt/Encryption at Rest
Region	Moderate	Confidential	DB Encrypt/Encryption at Rest
Country	Moderate	Confidential	DB Encrypt/Encryption at Rest
Postal Code	Moderate	Confidential	DB Encrypt/Encryption at Rest
Sole Proprietorship - Email	Moderate	Confidential	DB Encrypt/Encryption at Rest

Sole Proprietorship - Telephone / Fax Number	Moderate	Confidential	DB Encrypt/Encryption at Rest
Sole Proprietorship - Identification Number (internal unique identifier)	Moderate	Confidential	DB Encrypt/Encryption at Rest
Sole Proprietorship - Language Preference	Low	Confidential	DB Encrypt/Encryption at Rest
Partnership			
Partnership Banking Information	High	Confidential	DB Encrypt/Encryption at Rest
Financial Institution Number	High	Confidential	DB Encrypt/Encryption at Rest
Bank Branch	High	Confidential	DB Encrypt/Encryption at Rest
Bank Account Number	High	Confidential	Tokenize
Bank Identifier Code (BIC) for Large Value	High	Confidential	DB Encrypt/Encryption at Rest
Transfer System (LVTS) transactions only	High	Confidential	DB Encrypt/Encryption at Rest
Society for Worldwide Interbank Financial Telecommunication (SWIFT) Code	High	Confidential	DB Encrypt/Encryption at Rest
International Bank Number	High	Confidential	DB Encrypt/Encryption at Rest
Partnership – Tax number	High	Confidential	DB Encrypt/Encryption at Rest
Partnership - Address	Moderate	Confidential	DB Encrypt/Encryption at Rest
City	Moderate	Confidential	DB Encrypt/Encryption at Rest
Region	Moderate	Confidential	DB Encrypt/Encryption at Rest

Country	Moderate	Confidential	DB Encrypt/Encryption at Rest
Postal Code	Moderate	Confidential	DB Encrypt/Encryption at Rest
Partnership - Language Preference	None	Confidential	DB Encrypt/Encryption at Rest
Partnership - Email	None	Confidential	DB Encrypt/Encryption at Rest
Partnership - Telephone / Fax Number	None	Confidential	DB Encrypt/Encryption at Rest
Partnership - Identification Number (internal unique identifier)	None	Confidential	DB Encrypt/Encryption at Rest
Corporation			
Corporation – Name	None	Internal	DB Encrypt/Encryption at Rest
Corporation - Address	None	Internal	DB Encrypt/Encryption at Rest
City	None	Internal	DB Encrypt/Encryption at Rest
Region	None	Internal	DB Encrypt/Encryption at Rest
Country	None	Internal	DB Encrypt/Encryption at Rest
Postal Code	None	Internal	DB Encrypt/Encryption at Rest
Corporation - Language Preference	None	Internal	DB Encrypt/Encryption at Rest
Corporation Banking Information	None	Confidential	DB Encrypt/Encryption at Rest
Financial Institution Number	None	Confidential	DB Encrypt/Encryption at Rest
Bank Branch	None	Confidential	DB Encrypt/Encryption at Rest
Bank Account Number	None	Confidential	Tokenize

Bank Identifier Code (BIC) for Large Value	None	Confidential	DB Encrypt/Encryption at Rest
Transfer System (LVTS) transactions only	None	Confidential	DB Encrypt/Encryption at Rest
Society for Worldwide Interbank Financial Telecommunication (SWIFT) Code	None	Public	DB Encrypt/Encryption at Rest
International Bank Number	None	Confidential	DB Encrypt/Encryption at Rest
Corporation - Email	None	Confidential	DB Encrypt/Encryption at Rest
Corporation - Telephone / Fax Number	None	Confidential	DB Encrypt/Encryption at Rest
Corporation - Identification Number (internal unique identifier)	None	Confidential	DB Encrypt/Encryption at Rest
Corporation – tax number	None	Confidential	DB Encrypt/Encryption at Rest
Charity			
Charity – Name	None	Confidential	DB Encrypt/Encryption at Rest
Charity - Address	None	Confidential	DB Encrypt/Encryption at Rest
City	None	Confidential	DB Encrypt/Encryption at Rest
Region	None	Confidential	DB Encrypt/Encryption at Rest
Country	None	Confidential	DB Encrypt/Encryption at Rest
Postal Code	None	Confidential	DB Encrypt/Encryption at Rest
Charity - Language Preference	None	Confidential	DB Encrypt/Encryption at Rest

Charity Banking Information	None	Confidential	DB Encrypt/Encryption at Rest
Financial Institution Number	None	Confidential	DB Encrypt/Encryption at Rest
Bank Branch	None	Confidential	DB Encrypt/Encryption at Rest
Bank Account Number	None	Confidential	Tokenize
Bank Identifier Code (BIC) for Large Value	None	Confidential	DB Encrypt/Encryption at Rest
Transfer System (LVTS) transactions only	None	Confidential	DB Encrypt/Encryption at Rest
Society for Worldwide Interbank Financial Telecommunication (SWIFT) Code	None	Confidential	DB Encrypt/Encryption at Rest
International Bank Number	None	Confidential	Tokenize
Charity - Email	None	Confidential	DB Encrypt/Encryption at Rest
Charity - Telephone / Fax Number	None	Confidential	DB Encrypt/Encryption at Rest
Charity - Identification Number (internal unique identifier)	None	Confidential	DB Encrypt/Encryption at Rest
Charity – tax number	None	Confidential	DB Encrypt/Encryption at Re